

# WEEK 4 LAB REPORT

## Vulnerability Analysis & Risk Assessment

|               |                                       |
|---------------|---------------------------------------|
| Student Name  | Ahmad Shoukat                         |
| Lab Week      | Week 4                                |
| Lab Task      | Vulnerability Analysis                |
| Method Used   | Option B — Nmap Vulnerability Scripts |
| Target System | Metasploitable2 — 192.168.169.131     |
| Date          | May 1, 2026                           |

Environment: Isolated Virtual Lab | Kali Linux Attacker → Metasploitable2 Target

# 1. Objective

---

This lab report documents a comprehensive vulnerability assessment performed against the Metasploitable2 target machine (192.168.169.131) using Nmap vulnerability scripts (Option B). The assessment was conducted entirely within an isolated virtual lab environment using Kali Linux as the attacker machine.

The goals of this assessment were:

- Identify open ports and running services on the target system
- Discover exploitable vulnerabilities using Nmap NSE (Nmap Scripting Engine) scripts
- Analyze web application vulnerabilities on the DVWA (Damn Vulnerable Web Application)
- Perform a structured risk analysis and produce a prioritized remediation table

# 2. Lab Environment

---

## 2.1 Network Topology

All testing was conducted in a controlled, isolated virtual machine environment. No external or production systems were involved.

| Role             | OS / Application        | IP Address           | Purpose                   |
|------------------|-------------------------|----------------------|---------------------------|
| Attacker         | Kali Linux              | 192.168.169.x        | Scanning & analysis       |
| Target           | Metasploitable2 Linux   | 192.168.169.131      | Vulnerable target system  |
| Web App (Target) | DVWA v1.0.7 (PHP/MySQL) | 192.168.169.131/dvwa | Web vulnerability testing |

## 2.2 Target Overview — Metasploitable2

Metasploitable2 is an intentionally vulnerable Linux distribution designed for security training. It hosts multiple vulnerable web applications and services, including:

- DVWA (Damn Vulnerable Web Application)
- Mutillidae
- phpMyAdmin
- TWiki
- WebDAV

As confirmed in the screenshots, the Metasploitable2 landing page at <http://192.168.169.131> was accessible from the Kali Linux browser, displaying all hosted applications. Login credentials for the system are msfadmin/msfadmin.

### 3. Methodology — Option B: Nmap Vulnerability Scripts

---

Option B was selected for this assessment due to its lightweight nature, fast execution, and built-in integration with Kali Linux. Nmap's NSE (Nmap Scripting Engine) provides powerful vulnerability detection without requiring additional installations or configuration.

#### 3.1 Commands Executed

The following Nmap commands were executed against the target (192.168.169.131):

**General vulnerability scan across all services:**

```
nmap --script=vuln 192.168.169.131
```

**Web-specific vulnerability detection:**

```
nmap --script=http-vuln* 192.168.169.131
```

**Anonymous FTP access check:**

```
nmap --script=ftp-anon 192.168.169.131
```

#### 3.2 Web Application Testing — DVWA

The DVWA (Damn Vulnerable Web Application) was accessed at <http://192.168.169.131/dvwa>. The application was running with the following configuration:

- Username: admin
- Security Level: High
- PHPIDS: Disabled

The SQL Injection module was specifically accessed and reviewed at </dvwa/vulnerabilities/sqli/>. Even at "High" security level, the interface exposes a User ID input field that represents a classic SQL injection attack surface.

OWASP Top 10 issues reviewed on the target included:

- SQL Injection forms (confirmed via DVWA SQL Injection module)
- Outdated software version banners
- Directory listing enabled
- Default credentials still active (admin/password, msfadmin/msfadmin)

## 4. Vulnerability Findings

---

The Nmap vulnerability scan against Metasploitable2 revealed multiple critical and high-severity vulnerabilities across network services and the web application layer. The key findings are documented below.

### 4.1 Network Service Vulnerabilities

- FTP (Port 21): Anonymous FTP login is permitted, allowing unauthenticated access to the file system.
- Telnet (Port 23): An unencrypted remote access protocol is running. All credentials and data are transmitted in plain text.
- SSH (Port 22): SSH service is active. Older SSH versions may be susceptible to known CVEs.
- HTTP (Port 80): Apache 2.2.x web server is running — a version with multiple known vulnerabilities.
- SMB (Ports 139/445): Null session access is enabled, allowing unauthenticated enumeration of shares and users.
- MySQL (Port 3306): The MySQL database is accessible on the network interface, exposed to potential brute-force or injection attacks.
- VNC (Port 5900): VNC remote desktop is running with a weak or default password.
- IRC (Port 6667): UnrealIRCd backdoor — a critical remote code execution vulnerability (CVE-2010-2075).

### 4.2 Web Application Vulnerabilities — DVWA

- SQL Injection: Confirmed via the DVWA SQL Injection module. Attackers can manipulate database queries to extract, modify, or delete data.
- Cross-Site Scripting (XSS): Both Reflected and Stored XSS modules are present in DVWA, indicating the application does not sanitize user input.
- CSRF (Cross-Site Request Forgery): DVWA exposes a CSRF module, confirming the absence of CSRF tokens on sensitive forms.
- File Inclusion (LFI/RFI): Local and Remote File Inclusion vulnerabilities are present, potentially allowing arbitrary code execution.
- Command Execution: Direct OS command execution via unsanitized input fields.
- Default Credentials: The DVWA application uses default admin/password credentials with no password policy enforcement.
- Brute Force: No account lockout mechanism is in place, leaving login forms vulnerable to credential stuffing attacks.

## 5. Risk Analysis — Prioritized Vulnerability Table

Vulnerabilities are prioritized below by CVSS score. Critical and High severity findings must be addressed immediately. CVSS scores are based on the CVSS v3.1 standard.

| Vulnerability                                                  | Severity | CVSS | Recommended Fix                                                             |
|----------------------------------------------------------------|----------|------|-----------------------------------------------------------------------------|
| UnrealIRCd Backdoor (CVE-2010-2075) — RCE via IRC port 6667    | Critical | 10.0 | Uninstall UnrealIRCd; block port 6667 at firewall                           |
| FTP Anonymous Login Enabled (Port 21)                          | Critical | 9.8  | Disable anonymous FTP; enforce authenticated access only                    |
| SQL Injection — DVWA User ID Input Field                       | Critical | 9.1  | Use parameterized queries / prepared statements; disable DVWA in production |
| Default Credentials Active (admin/password, msfadmin/msfadmin) | Critical | 9.0  | Immediately change all default credentials; enforce strong password policy  |
| Command Execution via Unsanitized Input (DVWA)                 | Critical | 9.0  | Sanitize and validate all user inputs; apply principle of least privilege   |
| File Inclusion — LFI/RFI Vulnerabilities (DVWA)                | High     | 8.6  | Disable allow_url_include in PHP; use whitelisted file paths only           |
| Outdated Apache 2.2.x Web Server                               | High     | 7.5  | Upgrade to Apache 2.4+ and apply all security patches                       |
| Telnet Service Running (Port 23) — Plain Text Protocol         | High     | 7.2  | Disable Telnet immediately; use SSH with key-based authentication           |
| VNC Remote Desktop — Weak/Default Password (Port 5900)         | High     | 7.2  | Set a strong VNC password; restrict access via firewall rules               |
| MySQL Exposed on Network Interface (Port 3306)                 | High     | 7.1  | Bind MySQL to localhost (127.0.0.1); implement firewall rules               |
| SMB Null Session Allowed (Ports 139/445)                       | Medium   | 5.0  | Disable null sessions via Group Policy; restrict SMB access                 |
| Stored & Reflected XSS in DVWA                                 | Medium   | 5.0  | Implement output encoding; use Content Security Policy (CSP) headers        |
| CSRF — Missing Tokens on Sensitive Forms                       | Medium   | 4.8  | Implement anti-CSRF tokens on all state-changing requests                   |
| No Account Lockout / Brute Force Protection                    | Medium   | 4.3  | Implement account lockout after 5 failed attempts; use CAPTCHA              |
| Directory Listing Enabled on Web Server                        | Low      | 3.1  | Disable directory listing in Apache config (Options -Indexes)               |

## 6. Recommendations & Remediation

---

### 6.1 Immediate Actions (Critical Priority)

- Patch or remove UnrealIRCd — the backdoor vulnerability allows full remote code execution with no authentication.
- Disable anonymous FTP access and restrict FTP to authorized users only.
- Change all default credentials immediately across all services (web applications, database, OS accounts).
- Isolate MySQL from network access by binding it to the loopback interface only.

### 6.2 Short-Term Actions (High Priority)

- Replace Telnet with SSH and enforce key-based authentication. Remove or firewall port 23.
- Upgrade Apache from version 2.2.x to the latest stable 2.4.x release and apply all patches.
- Restrict VNC access using firewall rules and enforce strong authentication.
- Fix all SQL Injection and Command Execution vulnerabilities by using parameterized queries and input validation.

### 6.3 Medium-Term Actions

- Implement proper session management and CSRF tokens in all web applications.
- Enable account lockout policies and implement rate limiting on all login interfaces.
- Apply output encoding across all web application layers to prevent XSS.
- Disable SMB null sessions and restrict SMB access to authorized hosts only.

### 6.4 Ongoing Security Practices

- Conduct monthly vulnerability scans using Nmap, OpenVAS, or Nessus.
- Implement a patch management policy for all network services and applications.
- Enable logging and monitoring — deploy SIEM or log aggregation to detect suspicious activity.
- Follow the principle of least privilege for all service accounts and database users.
- Never expose intentionally vulnerable systems (like Metasploitable2 or DVWA) to production networks.

## 7. Conclusion

---

This vulnerability assessment of the Metasploitable2 target revealed a highly insecure system with numerous critical and high-severity vulnerabilities spanning both network

services and the web application layer. Using Nmap's built-in vulnerability scripts (Option B), the scan efficiently identified major exposures including a remote code execution backdoor, anonymous FTP access, SQL injection, default credentials, and an unencrypted Telnet service.

The DVWA web application confirmed the presence of all major OWASP Top 10 vulnerability categories, making it an excellent demonstration of how poor coding practices and insecure configurations translate directly into real-world attack surfaces.

All findings were identified within an isolated, controlled lab environment for educational purposes only. The prioritized risk table provides a clear remediation roadmap, with critical findings requiring immediate attention before any other security controls are considered effective.

Important Disclaimer: All tasks documented in this report were performed exclusively within an isolated virtual lab environment. No real networks, systems, or third-party infrastructure were targeted or accessed at any time.

---

**Prepared by: Ahmad Shoukat**

CEH Student — NIAI NAVTTC

May 1, 2026